

Instituto Tecnológico y de Estudios Superiores de Monterrey

Escuela de Ingeniería y Ciencias

Ingeniería en Ciencias de Datos y Matemáticas

Reporte Ejecutivo

Uso de Álgebras Modernas para Seguridad y Criptografía

Integrantes del equipo

Carola Vázquez Arjona	A01754562
Iker Álvarez Bandrés	A01282986
Juan Pablo Valdés Cárdenas	A00839013
Andrés Vivanco Treviño	A01723358
Juan Fernando González	A01571586
Carlos Eduardo Ramos Martínez	A01286025

Equipo 4 | Grupo 604

Profesores

Raúl Gómez, Anas Wajid y Alberto F. Martínez

Socio Formador

Casa Monarca, Ayuda Humanitaria al Migrante, A.B.P.

Monterrey, Nuevo León

12 de junio de 2026

Índice

1. Resumen Ejecutivo	1
2. Objetivo vs. Resultados	1
3. Solución Implementada	3
4. Impacto de Negocio	5
5. Lecciones y Hallazgos	6
6. Estado Actual y Próximos Pasos	7
Anexo: Repositorio del proyecto	8
Referencias	8

Índice de tablas

1.	Objetivos planteados y resultados obtenidos. ¹	1
2.	Impacto comparativo antes y después de la implementación de SIGAM. ²	5

1. Resumen Ejecutivo

Casa Monarca, Ayuda Humanitaria al Migrante, A.B.P. sufría una brecha de seguridad que comprometió información personal de su población atendida. El problema central era la ausencia de un sistema estructurado para la gestión de identidades digitales, el control de accesos y la protección documental, lo que dejaba los datos de personas migrantes y solicitantes de asilo expuestos a accesos no autorizados.

A lo largo de las dos etapas del reto se desarrolló el Sistema Institucional de Gestión para Casa Monarca (SIGAM), una plataforma web completa que integra cinco módulos operativos: gestión de identidades, infraestructura PKI, gestión de documentos, comunicación interna y comunicación externa segura. El sistema aplica esquemas criptográficos estándar de la industria (RSA-2048, SHA-256, bcrypt, S/MIME, JWT) y registra cada acción sensible en una bitácora institucional inmutable.

El resultado final es un sistema completamente funcional desplegable tanto en entorno local mediante contenedores Docker como en hosting compartido de producción (HostGator Plan Negocios). El impacto principal es la eliminación del manejo manual de información sensible de beneficiarios, garantizando autenticidad, integridad y trazabilidad en todos los flujos operativos críticos de la organización.

2. Objetivo vs. Resultados

Tabla 1: Objetivos planteados y resultados obtenidos.³

Objetivo	Estado	Observación
Módulo de gestión de identidades y roles (niveles 1–4)	Cumplido	Implementado con modelo de mínimo privilegio, permisos individuales por override y matrículas institucionales por área
Distinción entre externos con acceso y externos solo de comunicación	Cumplido	Flag <code>solo_comunicacion</code> en nivel 4, con flujos de activación diferenciados
Infraestructura PKI con certificados X.509	Cumplido	Emisión, renovación, revocación, verificación y reemisión vinculada a recuperación administrativa

Objetivo	Estado	Observación
Cifrado y hashing de datos sensibles	Cumplido	bcrypt para contraseñas, SHA-256 para integridad de archivos
Firma digital RSA-2048 en documentos, anuncios y mensajes	Cumplido	Proceso zero-knowledge vía API Web Crypto en el navegador
Repositorio documental con carpetas por área	Cumplido	Carpetas por área con conteo dinámico y carpeta virtual 'Sin clasificar'
Comunicación interna con firma obligatoria/opcional	Cumplido	Anuncios firmados obligatoriamente, mensajes con firma opcional
Canal de comunicación externa seguro	Cumplido	Página pública dedicada con firma local mediante Web Crypto API
Validación criptográfica de adjuntos en tres capas	Cumplido	Verificación de extensión, MIME y magic bytes, más detección de macros en archivos Office
Verificación periódica de integridad de adjuntos	Cumplido	Script cron diario con alertas firmadas al administrador en caso de discrepancia
Correos institucionales con S/MIME	Cumplido	Firmas detached conforme RFC 5751, adjunto smime.p7s, soporte de adjuntos múltiples
Verificador público de firmas S/MIME	Cumplido	Página pública <code>verificar.html</code> accesible sin autenticación
Cuenta espejo y recuperación administrativa	Cumplido	Flujo completo de recuperación con notificación al administrador y reemisión de certificado vinculada
Bitácora institucional inmutable	Cumplido	Registra todas las operaciones sensibles con timestamp, usuario y recurso afectado

Objetivo	Estado	Observación
Carpetas personales por colaborador	Pendiente	Identificado como mejora futura para la versión 2
Módulo de reportes y estadísticas	Pendiente	Identificado como mejora futura para la versión 2

3. Solución Implementada

El sistema desarrollado es una aplicación web de tres capas con separación estricta de responsabilidades, construida sobre PHP 8.2 con Apache (backend REST), HTML/CSS/-JavaScript vanilla (frontend SPA) y MySQL 8 (base de datos relacional). Se integran cinco módulos principales:

Gestión de identidades

Administra el ciclo de vida de colaboradores mediante cuatro niveles jerárquicos: Administrador (nivel 1), Coordinador (nivel 2), Operativo (nivel 3) y Consulta/Externos (nivel 4). Cada nivel hereda permisos base con posibilidad de overrides individuales. Las matrículas institucionales se asignan por área (HUM, PSI, LEG, COM, ALM, TI). Dentro del nivel 4 se distinguen dos subtipos: externos con acceso a la plataforma y externos exclusivos de comunicación, que reciben únicamente un link personal para enviar comunicaciones firmadas sin necesidad de iniciar sesión.

Infraestructura PKI y manejo zero-knowledge de llaves

La organización actúa como su propia autoridad certificadora, emitiendo certificados X.509 firmados con SHA-256. Cada certificado contiene los datos del titular, su llave pública RSA-2048 y fechas de vigencia. El sistema gestiona emisión, renovación, revocación, verificación y reemisión vinculada a recuperación administrativa. Las llaves privadas de los usuarios nunca se almacenan en el servidor: el proceso de firma ocurre íntegramente en el navegador mediante la API Web Crypto, preservando el valor probatorio de las firmas digitales.

³Elaboración propia.

Gestión de documentos

Organiza el repositorio por carpetas y áreas con autorización granular por colaborador. La integridad de cada archivo se garantiza mediante hash SHA-256 almacenado en base de datos, verificado periódicamente por un script cron diario que detecta manipulación post-recepción. Cada documento puede firmarse digitalmente por su autor, quedando la firma vinculada al certificado activo en el momento de la firma.

Comunicación interna

Los anuncios institucionales requieren firma digital obligatoria; los mensajes directos la admiten opcionalmente. Las reglas de comunicación se centralizan en un middleware que codifica quién puede escribirle a quién según nivel y área, garantizando que un colaborador no pueda contactar a usuarios fuera de su ámbito operativo.

Comunicación externa

Opera mediante tres componentes complementarios. El canal de entrada permite a externos previamente registrados enviar comunicaciones firmadas desde una página pública dedicada, sin necesidad de iniciar sesión. Los correos institucionales salientes se firman automáticamente con S/MIME (PKCS#7 detached, conforme al RFC 5751) usando el certificado del sistema, soportando adjuntos múltiples. El verificador público de firmas permite a cualquier destinatario externo confirmar la autenticidad de un correo recibido cargando el archivo .eml, sin requerir instalación previa de la autoridad certificadora institucional.

Validación criptográfica de adjuntos

Tanto el canal de entrada externa como los correos institucionales aplican validación en tres capas sobre cada archivo adjunto: extensión declarada contra lista blanca, tipo MIME detectado del contenido, y magic bytes binarios del formato. Para archivos Office se inspecciona adicionalmente la estructura ZIP interna para rechazar documentos con macros u objetos OLE embebidos. Cada archivo aceptado se procesa con SHA-256 y los intentos rechazados quedan registrados en una tabla de cuarentena con metadatos forenses.

Recuperación administrativa mediante cuenta espejo

Para el escenario en que el administrador principal pierda acceso a su cuenta, el sistema implementa una cuenta espejo: una segunda cuenta de nivel 1 asignada a otra persona

de confianza institucional, con permisos restringidos a una única operación, iniciar formalmente el procedimiento de recuperación del administrador principal. El procedimiento queda registrado en bitácora y dispara notificaciones firmadas con S/MIME a ambas partes.

Bitácora institucional

Registro inmutable de todas las operaciones sensibles del sistema. Permite reconstruir el histórico completo de acciones por usuario, recurso y timestamp. Las entradas se generan automáticamente desde los controladores antes de retornar respuestas exitosas, garantizando trazabilidad sin posibilidad de omisión.

4. Impacto de Negocio

Antes de la implementación, la gestión de documentos e identidades se realizaba de forma manual y sin controles diferenciados, lo que implicaba riesgo de exposición de información de personas en situación de vulnerabilidad. La solución introduce controles técnicos que mitigan directamente estos riesgos:

Tabla 2: Impacto comparativo antes y después de la implementación de SIGAM.⁴

Dimensión	Antes	Después
Control de acceso	Sin roles definidos	4 niveles con permisos granulares, overrides individuales y matrículas por área
Autenticación	Sin garantías técnicas	Contraseñas bcrypt + sesiones JWT con expiración
Integridad documental	Sin verificación	Firma digital RSA-2048 + hash SHA-256 con verificación diaria automatizada
Manejo de llaves privadas	Sin esquema definido	Zero-knowledge: las llaves nunca residen en el servidor, firma local en navegador con Web Crypto API

Dimensión	Antes	Después
Autenticidad de comunicaciones	Sin garantías	Firma obligatoria en anuncios, S/MIME en correos salientes con cobertura de adjuntos
Trazabilidad	Sin registro	Bitácora inmutable completa por operación, usuario y recurso afectado
Organización documental	Sin estructura	Carpetas por área con conteo dinámico y control de acceso granular
Comunicación con externos	Canal no seguro	Canal firmado con verificación criptográfica en tres capas más detección de macros en Office
Validación de adjuntos	Sin controles	Validación de extensión, MIME y magic bytes; cuarentena de rechazos con metadatos forenses
Verificación pública de firmas	No disponible	Endpoint público <code>verificar.html</code> para destinatarios externos
Recuperación administrativa	Sin procedimiento formal	Cuenta espejo con permisos restringidos, flujo auditado con reemisión de certificado vinculada
Riesgo de pérdida de documentos	Alto (sin validaciones)	Reducido: integridad verificada diariamente, eliminar carpeta requiere vaciarla previamente

5. Lecciones y Hallazgos

Entre los aspectos que funcionaron bien destacan:

- Adopción de UUID v4 como identificador primario en todas las entidades, garantizando unicidad sin exponer secuencias predecibles.

⁴Elaboración propia.

- Principio zero-knowledge para llaves privadas: el proceso de firma ocurre íntegramente en el navegador del usuario mediante la API Web Crypto, por lo que la llave privada nunca abandona el equipo del firmante.
- Defensa en profundidad en la validación de adjuntos mediante tres capas independientes (extensión, MIME, magic bytes) más detección de macros en archivos Office, cerrando los vectores de ataque más comunes contra organizaciones civiles.
- Separación deliberada entre la llave del sistema (para firmar correos S/MIME automáticos) y las llaves de los usuarios (zero-knowledge), preservando ambas garantías sin contradecirse.
- La carpeta virtual ‘Sin clasificar’ generada dinámicamente evitó registros huérfanos y simplificó la migración de datos históricos.
- Patrón de bitácora append-only que registra cada operación sensible antes de retornar respuestas exitosas, garantizando trazabilidad sin posibilidad de omisión.
- La separación de la arquitectura en tres capas independientes permitió despliegue tanto en Docker local como en hosting compartido sin modificaciones estructurales.

Como áreas de mejora identificadas:

- La ausencia de cifrado a nivel motor en la base de datos (TDE con AES-256) es una limitación consciente documentada; su implementación queda planteada como prioridad para la versión 2.
- La necesidad de definir requerimientos con mayor precisión antes de tomar decisiones de arquitectura, particularmente en lo relativo a carpetas privadas por colaborador.
- El flujo de renovación de certificados del administrador depende del cron diario de avisos y de la atención manual del titular ante las notificaciones recibidas. Una mejora identificada es agregar bloqueo preventivo automático cuando el certificado entra en ventana crítica.

6. Estado Actual y Próximos Pasos

El sistema se encuentra en estado de sistema funcional completo, con todos los módulos críticos operativos y verificados. La plataforma está lista para despliegue en producción en HostGator Plan Negocios sin modificaciones estructurales. Adicionalmente, se entrega como

parte del proyecto el manual de usuario operativo, el código fuente completo bajo licencia MIT en el repositorio público de GitHub, y las evidencias técnicas de cada flujo crítico del sistema.

Los próximos pasos recomendados son:

- Validar el sistema con el equipo de Casa Monarca en un entorno piloto controlado.
- Realizar la transferencia formal del sistema al equipo operativo de Casa Monarca, incluyendo capacitación del personal sobre resguardo de llaves privadas, identificación de phishing y manejo apropiado de información sensible.
- Implementar las mejoras de seguridad identificadas, priorizando el cifrado en reposo (TDE) y la activación de TLS en la conexión a la base de datos.
- Integrar un motor antivirus para análisis de contenido de los adjuntos, complementando la validación de formato actual.
- Establecer un proceso formal de respaldo y recuperación ante desastres con backups diarios cifrados.
- Iniciar el desarrollo de la versión 2 del sistema según el roadmap de mejoras documentado.

Anexo: Repositorio del proyecto

El código fuente completo del proyecto, junto con la documentación técnica, el manual de usuario, las evidencias de los casos de uso y los reportes ejecutivo y técnico, se encuentra disponible en el repositorio público de GitHub:

<https://github.com/carolavazquez/MA2006B>

El repositorio se distribuye bajo licencia MIT y contiene la estructura organizada en código fuente (`src/`), documentación (`docs/`), evidencias por caso de uso y el archivo `README.md` con las instrucciones de instalación, configuración y uso del sistema.

Referencias

Microsoft Learn. (s.f.). *Microsoft Entra ID documentation*. <https://learn.microsoft.com/en-us/entra/identity/>

Microsoft Learn. (s.f.). *Transparent Data Encryption (TDE) – SQL Server*. <https://learn.microsoft.com/en-us/sql/relational-databases/security/encryption/transparent>

National Institute of Standards and Technology. (2023). *Advanced Encryption Standard (AES)* (FIPS PUB 197, Update 1). <https://doi.org/10.6028/NIST.FIPS.197-upd1>

Microsoft Learn. (s.f.). *Azure Key Vault Overview*. <https://learn.microsoft.com/en-us/azure/key-vault/general/overview>

Internet Engineering Task Force. (2010). *RFC 5751 – Secure/Multipurpose Internet Mail Extensions (S/MIME) Version 3.2*. <https://www.rfc-editor.org/rfc/rfc5751>

Internet Engineering Task Force. (2009). *RFC 5652 – Cryptographic Message Syntax (CMS)*. <https://www.rfc-editor.org/rfc/rfc5652>